BaitFL Paper Review: Fixes, Graphs, Reviewer Report and Venues

Feedback on paper v7 (BaitFL: Lightweight Trap-Based Free-Rider Detection and Mitigation in Federated Learning)

1. What to fix before submitting

Blocking issues (a reviewer will stop here)

- **Unfinished experiments.** Section V-G says "baseline coverage remains provisional while the CIFAR-10 queue progresses," and the conclusion repeats it. A journal paper can't be submitted with an incomplete comparison.
- **Seed count never stated.** Your means (6.33, 41.67, 1.33) and ranges ([0-3]) show you ran **3 seeds**. The pooled 99.91% precision is computed over about 3,360 removals, but the independent sample is 96 runs. Use at least 5-10 seeds and report confidence intervals instead of pooled percentages.
- **No detection baseline.** STD-DAGMM appears only in the timing comparison, so your paper never shows whether BaitFL detects better, worse, or equally well. Add its detection results, plus a trivial baseline such as a MAD or norm threshold on ordinary updates, to show the traps are what matter.
- **Timing comparison.** It covers one configuration (non-IID, FR3, 40%), probably one run, and a five-epochs-per-round fitting budget you chose yourself. The 29%/26% savings are mostly STD-DAGMM's own cost, so lead with the 0.58% and 0.89% checking share. In Table V, the "Harness and unassigned" row is 6.82 s for STD-DAGMM and 0.0088 s for BaitFL, which suggests the instrumentation differs between the two.
- **Attacks are weak and non-adaptive.** You review Lin's, Fraboni's and Zhu's attacks but evaluate none of them. Add Fraboni's decaying-noise disguise, Zhu's scaled-delta and advanced attacks, and at least one trap-aware attacker.
- **Free-rider proportion.** Only 30% and 40% are tested, and Section VII-B admits that a group smaller than 10 clients can stay uncertified. Realistic cases are 5-20%, so run 0%, 5%, 10% and 20%. The 0% run, with honest clients only, is currently listed as future work. It is your false-positive test and should be in this paper.
- **Held-out evaluation.** Section VII-A says the design was "informed by experimental observations," and the cover says Code v15.4. Say how hyperparameters were chosen, and ideally tune on some seeds or attacks and test on others.

Segments to rework

- **Cover page and tone.** Remove "MSc Thesis", the code and paper versions, and lab-notebook phrases ("frozen implementation," "queue," "harness," "recorded host conditions," "paper-guided"). The Algorithm 4 line-13 edge case reads like a bug report, so fix the algorithm or drop it.
- **Abstract.** It is about 230 words and number-heavy. Cut the STD-DAGMM fitting detail and state the seed count.
- **Introduction.** The BaitFL paragraph is now a single sentence with no teaser of results. Add one sentence with the headline outcome. Also update the roadmap, which omits Complexity, Security and Limitations.
- **Method.** It is very dense. Add a notation table and a short intuition for why a perturbed starting point reveals free riders. A reader can't currently tell what honest and fake responses look like under a trap. Justify the odd conditions in Eq. 15 and the many hand-set constants (γ, W, L, I, review budget, cooldown).
- **Sections VII and VIII.** "Security Analysis" is really a limitations discussion, and it overlaps with VIII. Merge them into one "Discussion and Limitations" section.
- **Literature review.** Add a comparison table of the methods (auxiliary training, client cost, server cost, privacy exposure, needs attributable responses). Cover robust aggregation (Krum, median, trimmed mean, FLTrust), proof-of-learning and verifiable training, and Shapley-style contribution measurement. 15 references is thin for a Q1 journal, and 40-50 is typical.
- **Datasets and healthcare.** Your introduction motivates healthcare, but the datasets are MNIST and CIFAR-10. Add a medical dataset (e.g. from MedMNIST) or FEMNIST, and vary the Dirichlet α (0.1, 0.5, 1.0).
- **Tables.** Tables I and III duplicate the round-time column. Table II's headers are hard to parse ("Mean client-rounds," "All withheld"), and it hides FR1/FR2 rows. Table III's "min/run" lacks clear units.
- **Over-hedging.** Phrases like "support a low checking cost in the tested setting" and the repeated "does not establish" weaken the paper. Hedge once in the limitations and state results plainly elsewhere.
- **Possible PDF artifacts.** I noticed "thenuse," "Honestonly," and "receivedmodel." Check the source.

2. Graph and table suggestions

1. **Mechanism figure.** Violin or histogram of update norms for honest clients versus FR1-FR4 on ordinary models and on traps. This is the strongest argument that the traps help, and it is currently missing.
2. **Accuracy vs. round.** BaitFL, no-defense, an oracle FedAvg with honest clients only, and STD-DAGMM, with shaded standard deviation. The oracle is an important missing baseline.
3. **Client status heatmap.** For one run, clients on the y-axis and rounds on the x-axis, colored by clear, candidate, quarantined or removed, with free-rider identities marked. It makes the lifecycle (Fig. 2) concrete.
4. **Cumulative removal curves.** The fraction of free riders removed and the count of honest clients quarantined or removed over rounds. This is more informative than one completion round (Fig. 6).
5. **Ablation bars.** Full method versus no traps, norm-only, profile-only, no evidence memory and no bounded review. You say a matched ablation is needed, so do it.
6. **Sweeps.** Free-rider proportion (0-50%) and Dirichlet α against recall, honest quarantines and removal round. These show where the method breaks down.
7. **Scalability.** Detector-only time and memory against N (50 to 2000) on log-log axes with an $O(N^2)$ reference line. It is cheap to run without training and supports the "lightweight" claim beyond N = 100.
8. **Threshold-free separation.** AUROC of the norm score, profile score and combined score against baselines.
9. **Stacked bar of Table V.** It shows training dominating while checking is a sliver.
10. **Sensitivity/Pareto plot.** Varying γ, L and I, with detection quality against withheld participation.

3. Reviewer report

Summary. The paper proposes BaitFL, a server-side free-rider detector for federated learning. The server sends perturbed "trap" models and compares update norms and layer profiles among clients that received the same trap. Removal requires repeated fresh evidence, and bounded review limits the exclusion of unconfirmed clients. Experiments on MNIST and CIFAR-10 report 100% recall and 99.91% precision with low checking cost.

Strengths

- The problem is relevant, and the hidden-challenge idea is a sensible alternative to auxiliary detectors.
- The design is careful about false positives, with separate evidence components, expiring review and rehabilitation.
- Honest-client cost is reported openly, including honest removals and quarantine rounds.
- The limitations are candid, including the secure-aggregation incompatibility.

Major concerns

1. **Evidence is too thin for the claims.** With 3 seeds, "100% recall" and "99.91% precision" are not statistically meaningful. There are no confidence intervals, and the complete honest-only (0% free rider) case is untested.
2. **Weak and mismatched evaluation.** The attacks are simple and non-adaptive, and the strongest published ones are discussed but not tested. A detector that is tuned over many code versions and tested on its own attacks risks overfitting.
3. **No comparative detection results.** There is no detection comparison with STD-DAGMM, FRAD, PASS or FRIDA, and no simple threshold baseline. The timing comparison is a single configuration against a reimplementation with an author-chosen training budget.
4. **Unproven mechanism.** The paper never shows why traps help, and there is no ablation against passive screening. The method is a heuristic pipeline with many hand-set parameters and no false-positive guarantee. The bootstrap intervals are admittedly not calibrated.
5. **Weak behavior under heterogeneity.** In non-IID FR3 at 40%, about 72% of honest clients remain candidates (37 of 60 on MNIST, 43 on CIFAR-10). Honest removals happen only in this regime, and 11-17% of honest client-rounds are withheld. This conflicts with the "lightweight" and "honest-safe" framing.
6. **Operating range is narrow.** Only 30-40% attackers, N = 100, and one small architecture per dataset. The cohort rule ($\geq\sqrt{N}$) cannot catch small groups, and the quadratic cost is untested at scale.
7. **Adaptivity.** Trap-aware or collusive attackers are explicitly out of scope, yet the abstract frames the method as general.

Minor points

- Table I and Table III duplicate columns, Table II's headers are unclear, and the comparison tables lack standard deviations.
- Equal-weight aggregation differs from the usual sample-size weighting.
- The thesis and lab-notes language should go.
- The literature review is narrow and the references are few.
- Code and data availability should be stated with a persistent link.

Questions for the authors

- What happens with 0% and 5% free riders?
- What is the false-positive rate on honest-only non-IID populations?
- How does detection change with trap strength γ, and what does a trap-aware attacker do?
- Can the savings over STD-DAGMM survive a tuned fitting budget?

Recommendation: major revision. The idea is promising but the evidence doesn't yet support the claims.

4. Where to submit

I can't check current quartiles or impact factors from here, and they vary by category and year, so confirm on SCImago or JCR before you decide. The shortlist below is from memory.

Realistic first targets (fit the topic, moderate bar once you fix the blocking issues)

- **IEEE Internet of Things Journal.** PASS and FRAD both appeared here, so it is the closest topical fit and a Q1 venue.
- **Journal of Information Security and Applications.** FRIDA appeared here. Check its current quartile.
- **Computers & Security** and **Information Sciences** (Elsevier). Both are solid Q1 venues for security-flavored ML.
- **Future Generation Computer Systems** and **Journal of Network and Computer Applications.** Good fits for the distributed-systems side and the cost analysis.

Stretch targets (need adaptive attacks, baselines and larger scale)

- **IEEE Transactions on Information Forensics and Security**

- **IEEE Transactions on Dependable and Secure Computing**
- **IEEE Transactions on Neural Networks and Learning Systems**

Broad option: Scientific Reports (Nature), which is a Q1 venue but has a high article fee and a less specialized audience.

With the current draft I'd aim at the first group, and only consider the stretch group after adding the stronger attacks, baselines, ablations and larger-scale runs. If your university requires thesis-derived papers to follow specific rules, check those before choosing.